

Relatório do trabalho de grupo

Proposta de controle de acessos para mini servidor linux

Síntese do Cenário

A equipa pretende colocar em funcionamento um mini-servidor Linux para alojar uma aplicação web, servido por quatro perfis distintos: Administrador, Operador web, Auditor e Visitante técnico. Os principais riscos identificados incluem a utilização de uma conta compartilhada por todos, permissões excessivas em diretórios críticos, uso frequente da conta *root*, acesso SSH sem regras definidas e ausência de documentação sobre privilégios. Esta proposta visa resolver esses problemas aplicando o princípio do menor privilégio, segregação de funções e controles de acesso remoto seguros.

Perfil e Responsabilidade				
Perfil	Grupo	Responsabilidades	Permissoes necessarias	Permissoes a evitar
Administrador do sistema	adminis	Gerir utilizadores, Grupos,serviços e atualizações	Sudo completo,leitura/escrita em/etc,acesso SSH	Login direto como root, partilha de credenciais
Operador web	webops	Publicar atualizar ficheiros da aplicação web	Leitura/escrita em/opt/projeto-web/public	Acesso a /config e/logs, uso de sudo
Auditor	auditores	Consultar logs,evidências e documentos	Leitura em/logs e/docs	Escrita em qualquer directório, acesso a /config
Visitante tecnico	Visitantes	Consultar documentação pública autoriz	Leitura em/docs	Qualquer acesso a/config/logs ou/public

Comandos de criar grupos e utilizadores

- Sudo groupadd admins.
- Sudo groupadd webops.
- Sudo groupadd auditores.
- Sudo groupadd visitantes.
- Sudo useradd -m -s /bin/bash -G admins alice.
- Sudo useradd -m -s /bin/bash -G webops bob.
- Sudo useradd -m -s /bin/bash -G auditores carol.
- Sudo useradd -m -s /bin/bash -G visitantes dave.

Estrutura de repositórios

Directorio	Conteudos	Poder ler	Poder escrever	Sem acesso	Riscos se excessivo
public	Ficheiros da app web	webops, auditores	webops	visitantes(directamente)	Alteração indevida de conteúdo público
config/	Configs sensíveis, chaves, .env	admins	admins	webops, auditores, visitantes	Exposição de credenciais e chaves privadas
logs	Logs de acesso e erros	Adminis, auditores	adminis(sistema)	Webops, visitantes	Manipulação ou eliminação de evidências
docs/	Documentação técnica	Todos grupos	adminis	-	Distribuição de informação interna sensível

Proposta de permissao			
Caminho	Dono/Grupo	Permissao	Justificação
/ops/projeto-web/	root/admins	750	Apenas admins academ a raiz do projeto
/ops/projeto-web/public/	Root / webops	775	Webops pode publicar, outros leem via servidor
/ops/projeto-web/config/	root/admins	700	Exclusivo a adminis-contêm dados sensíveis
/ops/projeto-web/logs/	root/auditores	750	Auditores leem apenas o sistema escreve
/ops/projeto-web/docs/	root/visitantes	755	Leitura pública no servidor, escrita apenas por admins

Regras de acesso Remoto SSH			
Perfil	Acesso SSH	Autenticação	Justificação
Administrador	Sim	Chave SSH, sudo para operações privilegiadas	Apenas admins academ a raiz do projeto
Operador Web	Sim(restrito)	Chave SSH, acesso limitado a /ops/projeto-web/ public/	Publicação de conteúdo, restringir via chroot ou rsync
Auditor	Sim(so leitura)	Chave SSH, acesso apenas a /logs e /docs	Recolha de evidências sem risco de alteração

Regras de acesso Remoto SSH

Perfil	Acesso SSH	Autenticação	Justificação
Visitante tecnico	Nao	-	Sem necessidade operacional,risco desnecessário

Regras importantes

- Nunca dar acesso SSH ao root direto.
- Sempre usar chaves SSH em vez de passwords.
- Nunca dar acesso a quem não precisa.
- O visitante técnico acede apenas via browser ou documentação partilhada.

Comandos de configuração SSH.

- Sudo nano /etc/ssh/sshd_config.
- PermitRootLogin no.
- PasswordAuthentication no.
- PubkeyAuthentication yes.
- AllowGroups admins webops auditores.
- MaxAuthTries 3.
- ClientAliveInterval 300.
- Sudo systemctl restart ssh.

Riscos e Medidas de mitigação		
Riscos	impacto	Medidas de mitigação
Conta partilhada por todos	Alto-impossível rastrear acesso individual, comprometendo total se a password vazar	Criar contas individuais por perfil,desativar contas genéricas
Permissões excessivas em /config/	Crítico-exposição de credenciais,chaves e parâmetros sensíveis	Chmod 700 em /config/acesso exclusivo ao grupo admins
Uso frequente da conta root	Alto-qualquer erro o comprometimento afeta todo o sistema	Desativar login root via ssh, usar sudo com regras granulares(sudoers)
Acesso ssh sem regras claras	Alto-porta de escrita para instrução,ataque de brute force	Desativar automatização de login por password, usar chaves ssh, restringir allowGroups
Logs e evidências alteráveis por operadores	Médio-adulteração de provas em caso de incidente	Permissão 750 em /logs/apenas sistema escreve, auditores só leem
Falta de documentação sobre privilégios	Medio-acumulação de privilegio ao longo tempo(privilege creep)	Manter tabelas de acesso atualizada, revisão semestral de contas e grupos

Conclusao

A proposta apresentada aplica de forma coerente o princípio do menor privilégio, cada utilizador dispõe apenas das permissões estritamente necessárias ao desempenho das suas funções. A segregação em quatro grupos (admins, webops, auditores, visitantes) reduz a superfície de ataque e permite rastrear responsabilidades de forma clara. A estrutura de diretórios garante isolamento entre dados públicos, configurações sensíveis, logs de auditoria e documentação. As regras SSH eliminam os vetores de acesso mais comuns (login root, autenticação por password) e limitam o SSH apenas aos perfis que dele necessitam. A documentação de riscos e medidas de mitigação assegura que a equipa conhece as vulnerabilidades existentes e sabe como responder. A revisão periódica das contas e privilégios é essencial para manter a postura de segurança ao longo do tempo.